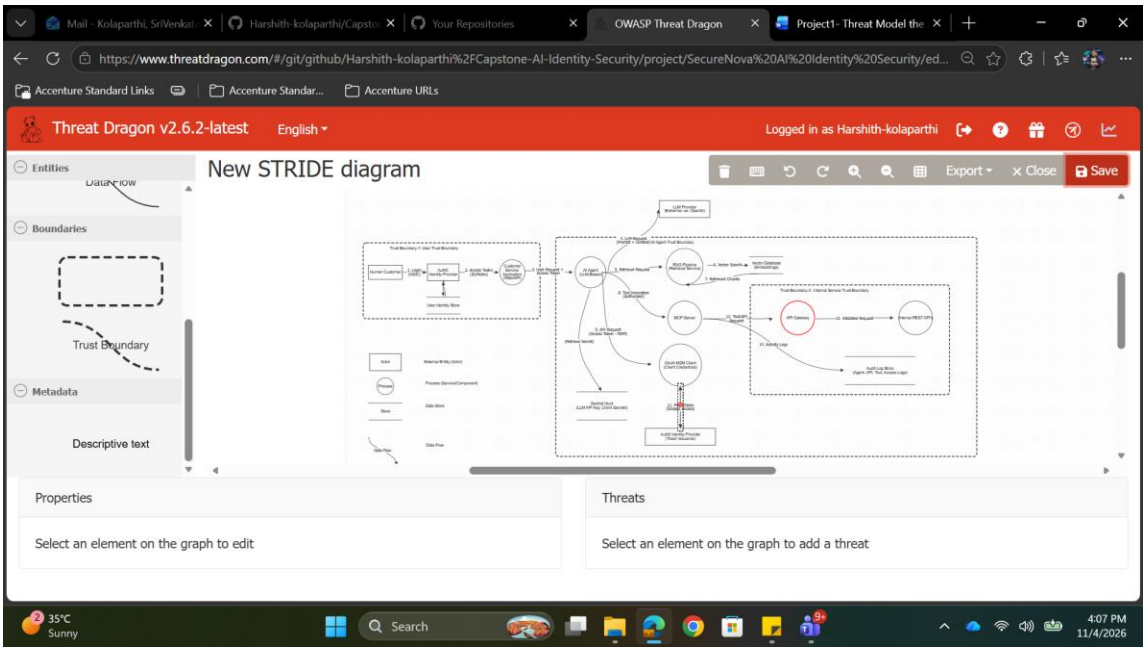
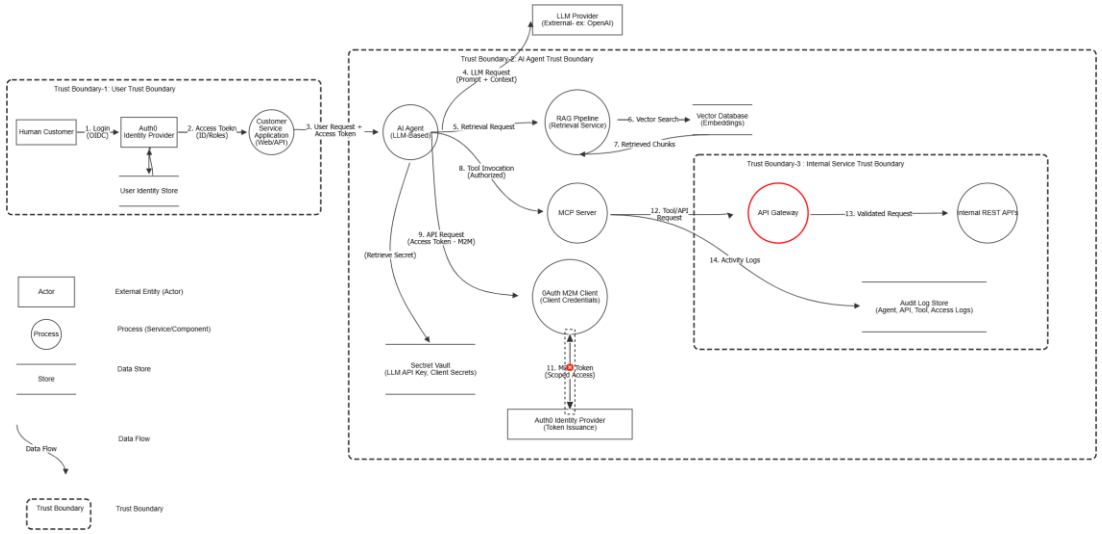
Capstone

Project-1: Threat Model AI Identity System

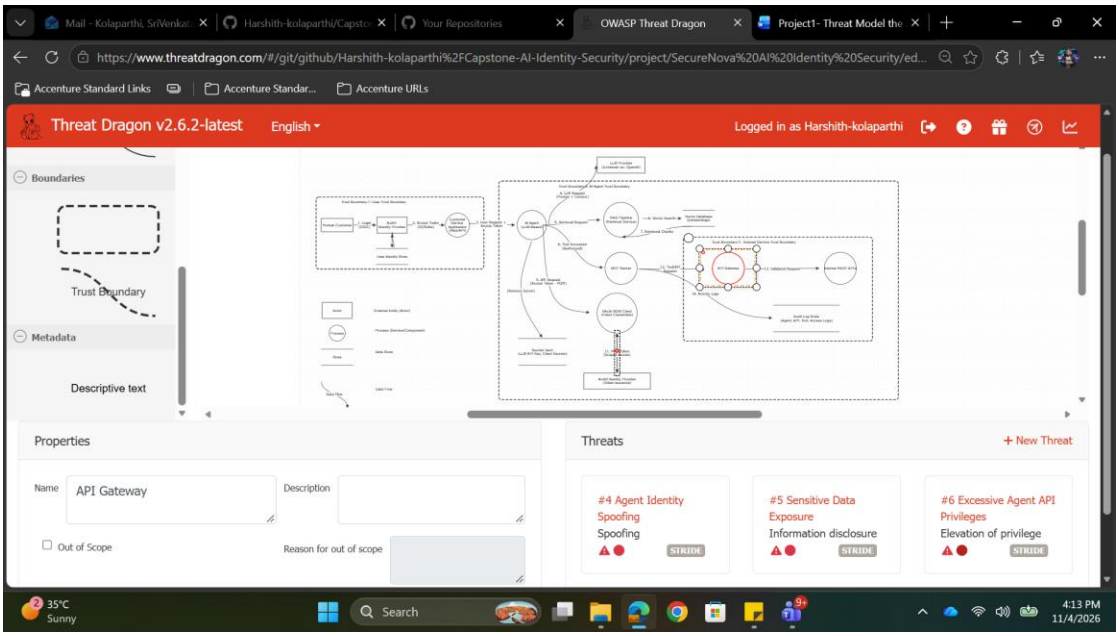
1. OWASP Threat Dragon open in Browser – complete data flow diagram with all identity components and trust boundaries labelled.



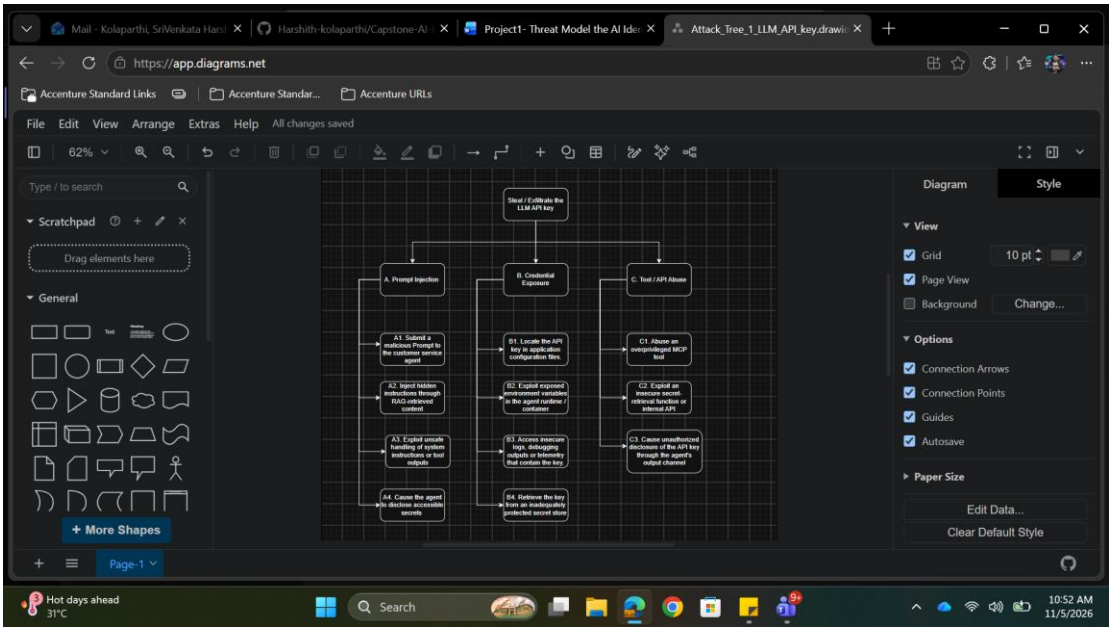
Clear data flow image for reference



2. Threat Dragon threat panel showing at least 3 STRIDE threats populated for one identity flow.



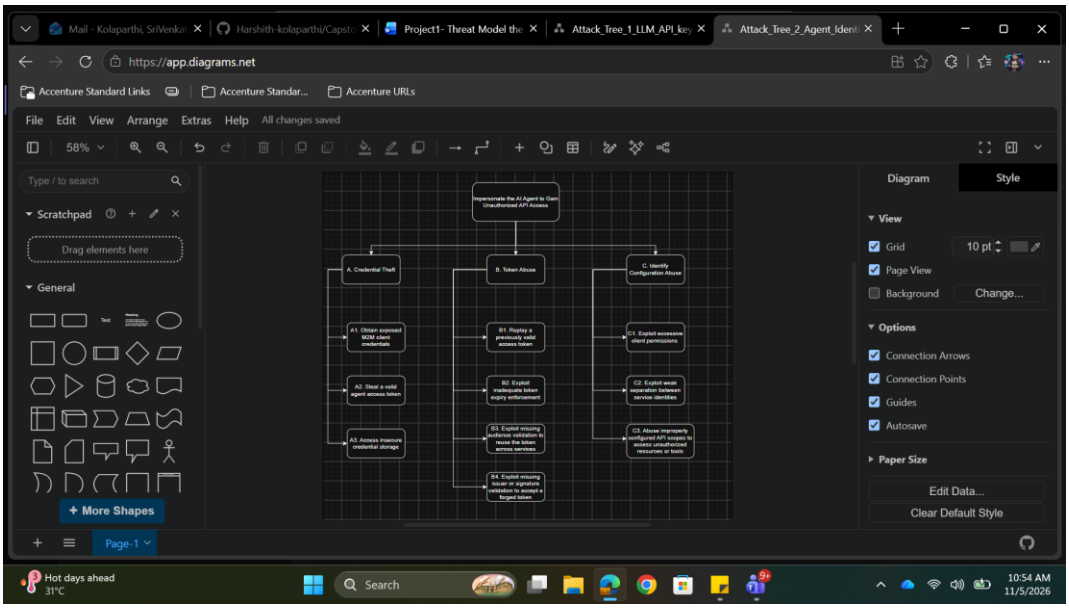
3. Attack Tree 1 (LLM API key exfiltration) with all nodes and goal at top visible.



Risk Assessment :

Likelihood * Impact = Risk Score => 4/5 * 5/5 = 20/25

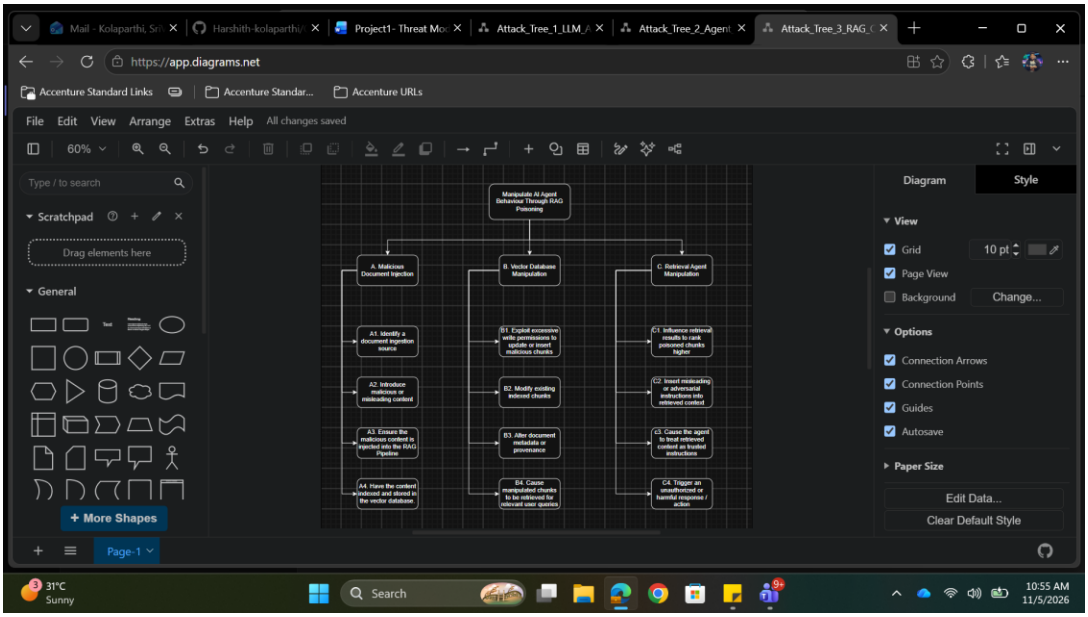
4. Attack Tree 2 (Agent Identity spoofing) with all nodes visible.



Risk Assessment :

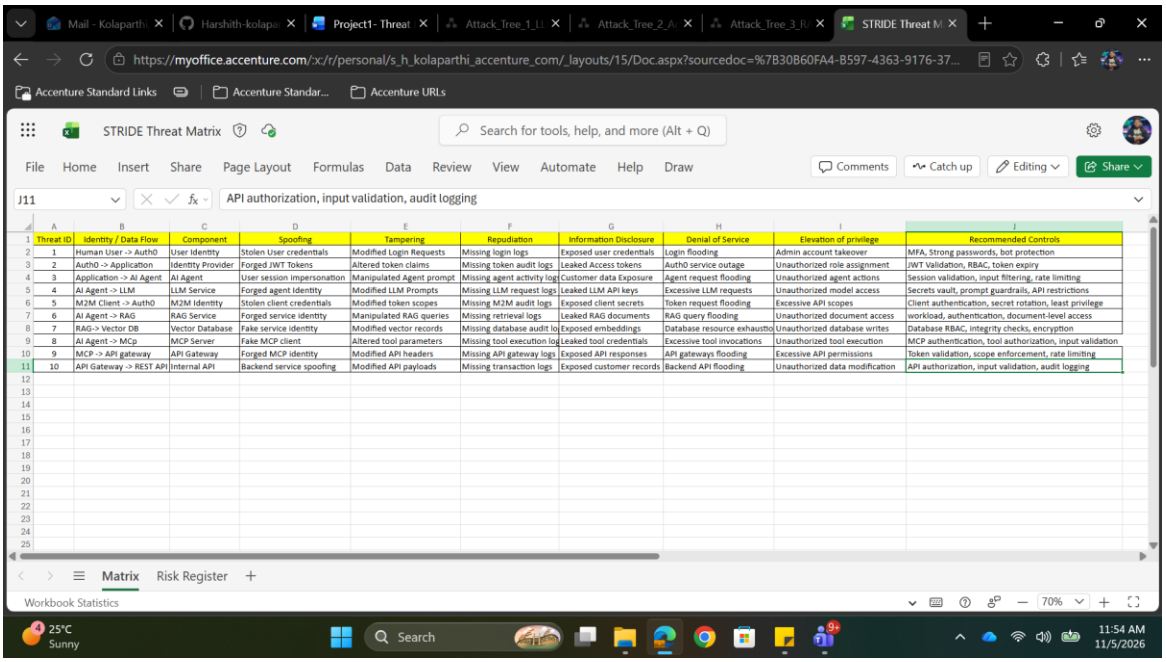
Likelihood * Impact = Risk Score => 4/5 * 5/5 = 20/25

5. Attack Tree 3 (RAG chunk poisoning) with all nodes visible.



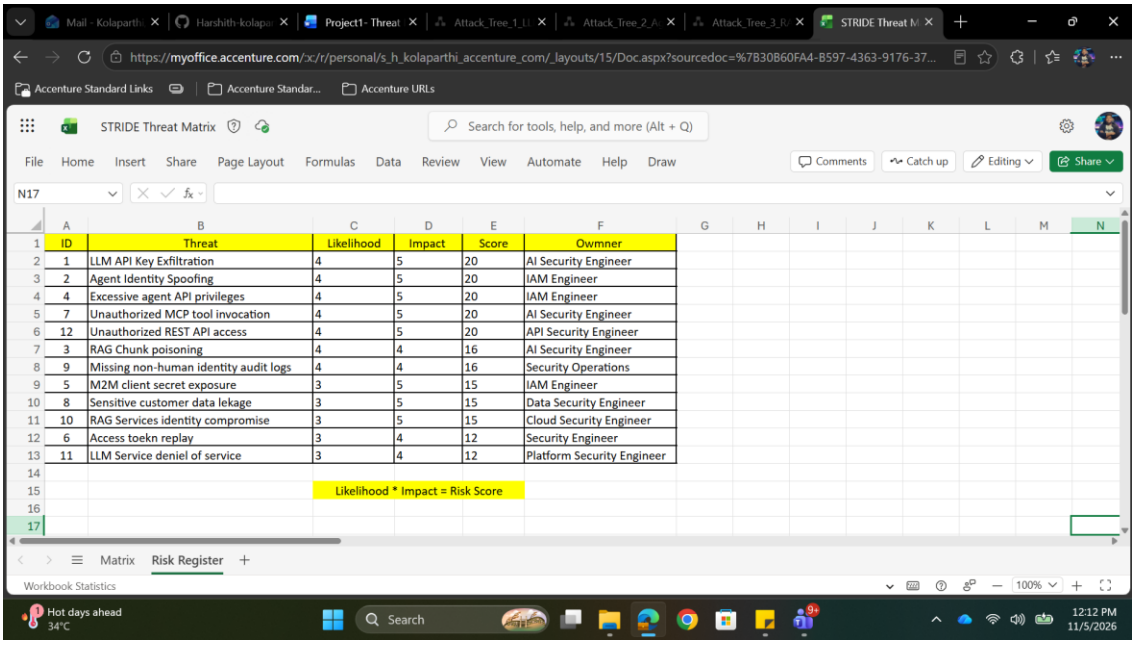
Risk Assessment : Likelihood * Impact = Risk Score => 4/5 * 4/5 = 16/25

6. STRIDE threat matrix fully populated – all rows and all six categories completed.



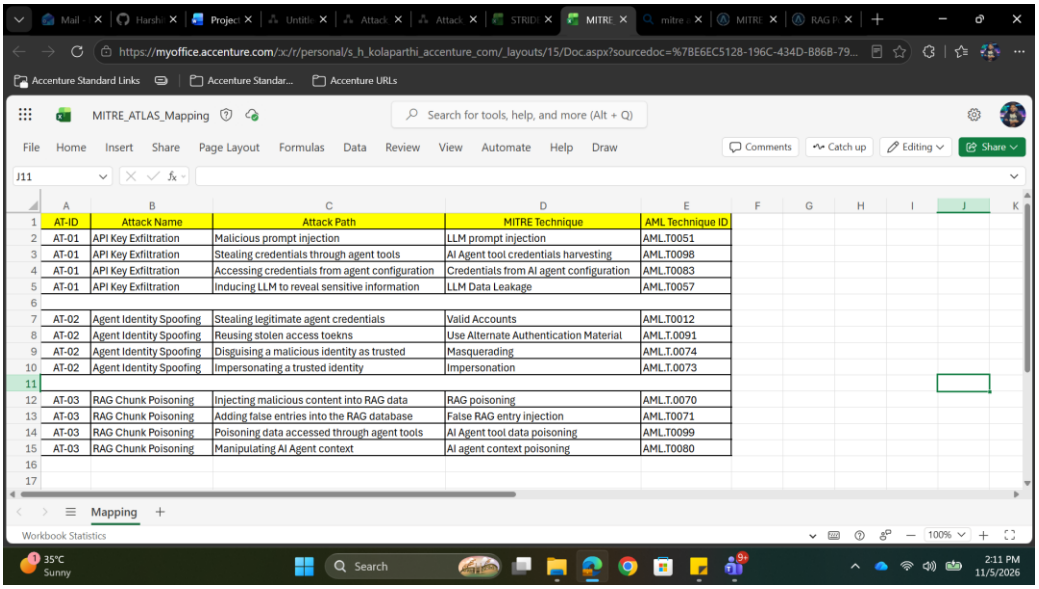
Threat ID	Identity / Data Flow	Component	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of privilege	Recommended Controls
1	Human User -> Auth0	User Identity	Stolen User credentials	Modified Login Requests	Missing login logs	Exposed user credentials	Login flooding	Admin account takeover	MFA, Strong passwords, bot protection
2	Auth0 -> Application	Identity Provider	Forged JWT Tokens	Altered token claims	Missing token audit logs	Leaked Access tokens	Auth0 service outage	Unauthorized role assignment	JWT Validation, RBAC, token expiry
3	Application -> AI Agent	AI Agent	User session impersonation	Manipulated Agent prompt	Missing agent activity log	Customer data Exposure	Agent request flooding	Unauthorized agent actions	Session validation, input filtering, rate limiting
4	AI Agent -> LLM	LLM Service	Forged agent Identity	Modified LLM Prompts	Missing LLM request logs	Leaked LLM API keys	Excessive LLM requests	Unauthorized model access	Secrets vault, prompt guardrails, API restrictions
5	M2M Client -> Auth0	M2M Identity	Stolen client credentials	Modified token scopes	Missing M2M audit logs	Exposed client secrets	Token request flooding	Excessive API scopes	Client authentication, secret rotation, least privilege
6	AI Agent -> RAG	RAG Service	Forged service identity	Manipulated RAG queries	Missing retrieval logs	Leaked RAG documents	RAG query flooding	Unauthorized document access	workload, authentication, document-level access
7	RAG -> Vector DB	Vector Database	Fake service identity	Modified vector records	Missing database audit log	Exposed embeddings	Database resource exhaustion	Unauthorized database writes	Database RBAC, integrity checks, encryption
8	AI Agent -> MCp	MCP Server	Fake MCP client	Altered tool parameters	Missing tool execution log	Leaked tool credentials	Excessive tool invocations	Unauthorized tool execution	MCP authentication, tool authorization, input validation
9	MCP -> API gateway	API Gateway	Forged MCP identity	Modified API headers	Missing API gateway logs	Exposed API responses	API gateways flooding	Excessive API permissions	Token validation, scope enforcement, rate limiting
10	API Gateway -> REST API	Internal API	Backend service spoofing	Modified API payloads	Missing transaction logs	Exposed customer records	Backend API flooding	Unauthorized data modification	API authorization, input validation, audit logging

7. Risk register spreadsheet open – all threats scored and ranked by Risk score, atleast 10 rows visible.



ID	Threat	Likelihood	Impact	Score	Owmner
1	LLM API Key Exfiltration	4	5	20	AI Security Engineer
2	Agent Identity Spoofing	4	5	20	IAM Engineer
4	Excessive agent API privileges	4	5	20	IAM Engineer
7	Unauthorized MCP tool invocation	4	5	20	AI Security Engineer
12	Unauthorized REST API access	4	5	20	API Security Engineer
3	RAG Chunk poisoning	4	4	16	AI Security Engineer
9	Missing non-human identity audit logs	4	4	16	Security Operations
5	M2M client secret exposure	3	5	15	IAM Engineer
8	Sensitive customer data lekage	3	5	15	Data Security Engineer
10	RAG Services identity compromise	3	5	15	Cloud Security Engineer
6	Access toekn replay	3	4	12	Security Engineer
11	LLM Service deniel of service	3	4	12	Platform Security Engineer

8. MITRE ATLAS website showing the AML.TXXXX technique page for one of your three mapped attack trees.
    - Attack Trees mapping



AT-ID	Attack Name	Attack Path	MITRE Technique	AML Technique ID
AT-01	API Key Exfiltration	Malicious prompt injection	LLM prompt injection	AML.T0051
AT-01	API Key Exfiltration	Stealing credentials through agent tools	AI Agent tool credentials harvesting	AML.T0098
AT-01	API Key Exfiltration	Accessing credentials from agent configuration	Credentials from AI agent configuration	AML.T0083
AT-01	API Key Exfiltration	Inducing LLM to reveal sensitive information	LLM Data Leakage	AML.T0057
AT-02	Agent Identity Spoofing	Stealing legitimate agent credentials	Valid Accounts	AML.T0012
AT-02	Agent Identity Spoofing	Reusing stolen access toekns	Use Alternate Authentication Material	AML.T.0091
AT-02	Agent Identity Spoofing	Disguising a malicious identity as trusted	Masquerading	AML.T.0074
AT-02	Agent Identity Spoofing	Impersonating a trusted identity	Impersonation	AML.T.0073
AT-03	RAG Chunk Poisoning	Injecting malicious content into RAG data	RAG poisoning	AML.T.0070
AT-03	RAG Chunk Poisoning	Adding false entries into the RAG database	False RAG entry injection	AML.T0071
AT-03	RAG Chunk Poisoning	Poisoning data accessed through agent tools	AI Agent tool data poisoning	AML.T0099
AT-03	RAG Chunk Poisoning	Manipulating AI Agent context	AI agent context poisoning	AML.T0080

- Attack Tree 3 mapping with the MITRE ATLAS

